Mission: Resilient

Your OT Cybersecurity Maturity Made Possible*

Mandie Grosskopf

*Dinosaurs sold separately

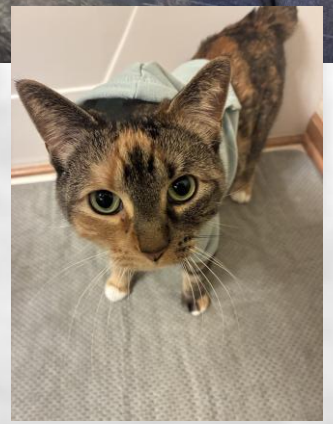
Agenda

Word of the Day:
"Equifinality"
Noun.
Principle that in open systems a given end state can be reached by many potential means.
-*Wikipedia*

- Introductions
- What makes protecting dinosaurs so hard
- Three common profiles along their OT security maturity journey
- Conclude & Questions

About Me

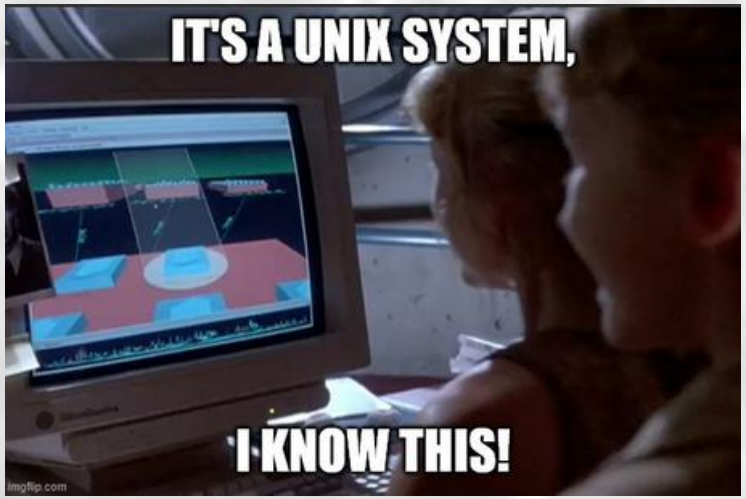
Mandie Grosskopf, GIAC Response & Industrial Defense, Cybersecurity Analyst+, Security+, Network+, Security Analytics Professional



Manager at Security Risk Advisors

- Philadelphia-based company, plus Rochester, NY, and Kilkenny, Ireland, offices
- Remote worker from Minneapolis/St. Paul, MN
- Adventurous eater & traveler
- Human staff for two cats
- Crochet's cool, but have you ever just collected yarn?
- Vibes are mulled wine, fuzzy blanket, and a good book in front of the fireplace while the snow falls

What's the prob, Bob?



Intrusions into OT spaces have declined overall!

…but 50% of respondents still have one or more incidents per year*

Higher self-assessed maturity levels correlate to reduced intrusions!

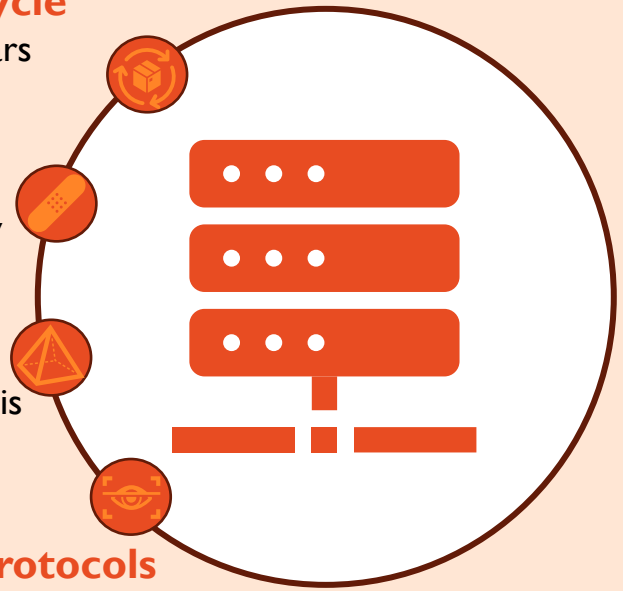
…but total attacks went up 5%, and most attacks impacted multiple physical sites**

…and almost 90% of indirect attacks on OT had physical consequences**

*2025 Fortinet State of Operational Technology & Cybersecurity Report
**Waterfall Security/ICS Strive, 2025 OT Cyber Threat Report

What makes up a dinosaur

Information Technology



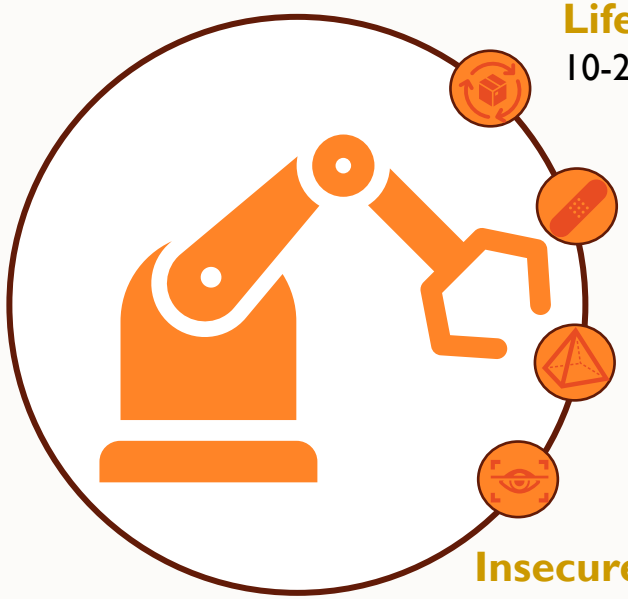
Lifecycle
3-5 years

Updates & Patches
Frequent, usually monthly

CIA Triad
Confidentiality of data is often the priority

Modern, Secure Protocols
Less backwards compatibility needs

Operational Technology



Lifecycle
10-20 years+

Updates & Patches
Infrequent, maybe yearly

(S)AIC Triad
Safety, availability of machinery is priority

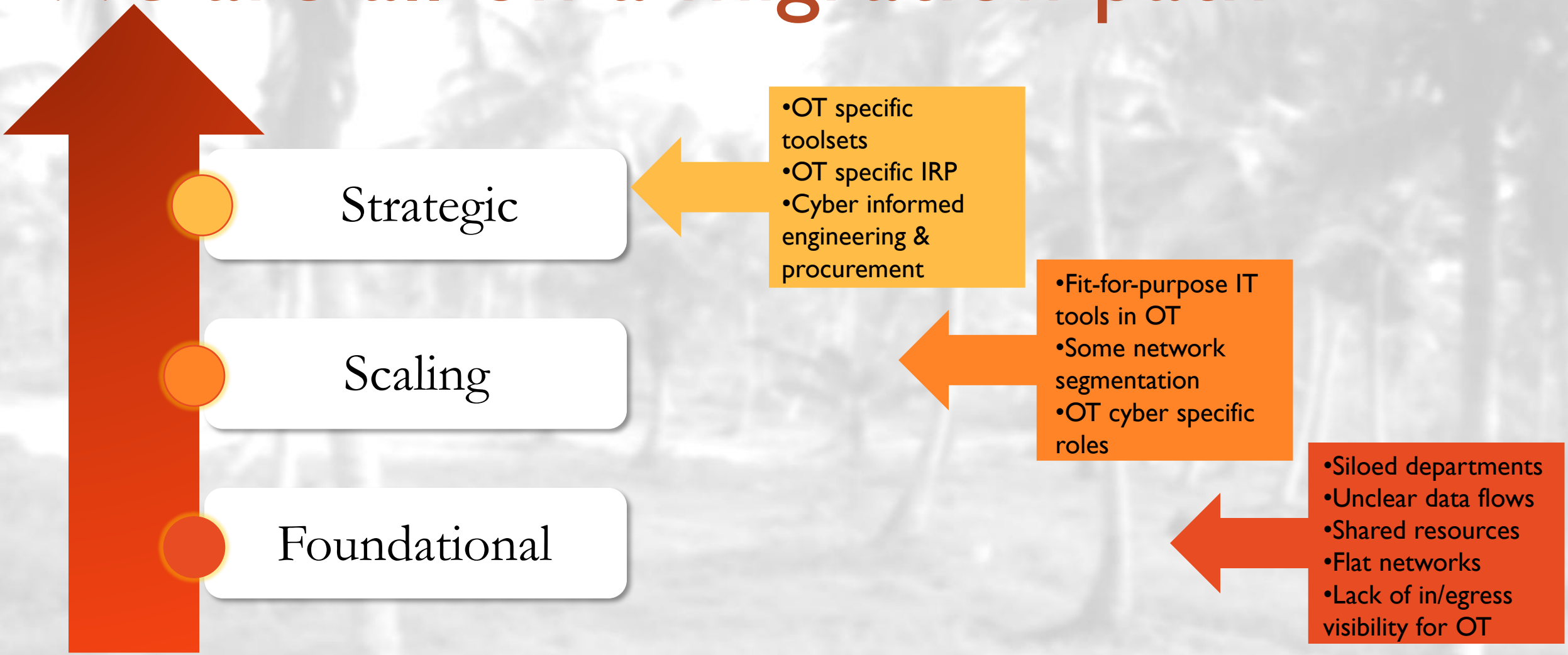
Insecure by Design Protocols
High need for backwards compatibility

Maturity vs Risk Assessment

There are several important differences between a Maturity Assessment and a Risk Assessment. This talk focused on assessing current **Maturity levels**, *not* specific risks.

	★★★ Maturity Assessment: ★★★	Risk Assessment:
Focus	Measure capabilities in cybersecurity practices to **respond to risks and threats**; and how practices are developed, implemented, and continuously improved.	Identifying, analyzing, evaluating, and cataloguing **specific risks and exposure to threats**, and any compensatory controls protecting assets and infrastructure.
Outcome	Understanding benchmarks against industry standards and best-practices to **identify gaps in maturity** and design a **prioritized growth roadmap**.	A **risk register** that contains initial and residual risks with severity ratings as well as risk responses, such as acceptance or deference.

We are all on a migration path



Foundational: Building Fences

Develop OT asset inventory and visibility

Develop clear network zones and basic segmentation

Define roles and responsibilities between IT, OT and InfoSec

Secure, logged remote access, including vendors

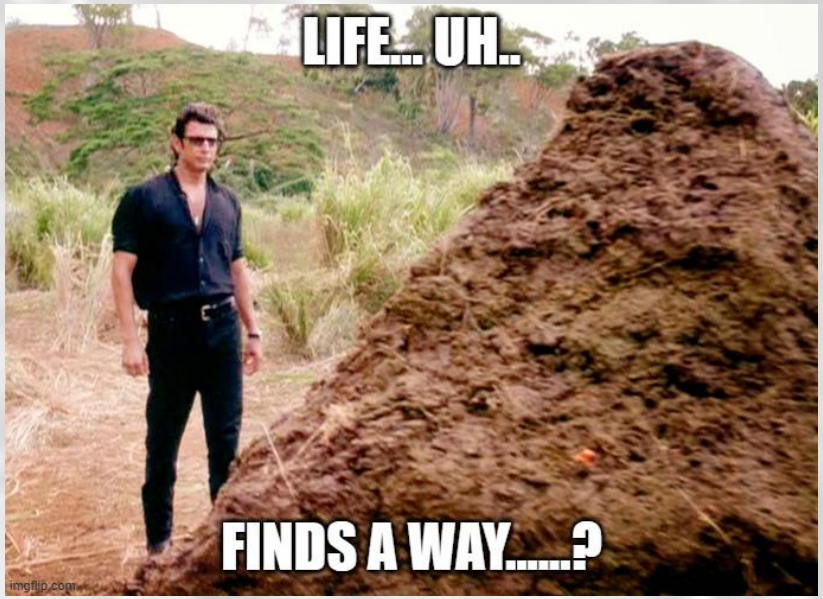
When legacy OT is running the park

Ask Yourself:

1. Is my asset inventory fractured between IT and OT?
2. Do I know what IR containment steps I can take on OT assets?
3. How do IT / OT connect?
4. Can I track who connects remotely to OT, and how do they do it?

Help Yourself:

1. Update and create a process to regularly update your CMDB
2. Check sites for BCP/DR documentation to determine asset ownership and risk acceptance
3. Diagram data flows inside OT and between IT/OT
4. Consider your IR processes and if they cover OT



Scaling: Containment & Control

Incorporate OT stakeholders and perspectives in governance, BCP / DR planning and change management

Implement OT barriers to entry like OT Firewalls, Industrial DMZs, secure remote access

Test communications & process flow between IT, OT and InfoSec with Tabletop Exercises

Deploy OT-specific monitoring and anomaly detection, with IR playbooks

Containment is everything

Ask Yourself:

1. If malware were to hit the IT side, what tools do I have to detect and contain it?
2. Do I understand and monitor paths malware could take to get to my OT environment?
3. Do I know what abnormal behavior would look like in my OT environment?

Help Yourself:

1. Create a RACI matrix outlining roles and responsibilities between teams
2. Map interdependencies and requirements for OT and IT
3. Incorporate OT into your existing IRP, or create a standalone OT IRP and a process to invoke it from existing

Strategic: Designing for Decades

OT-specific cybersecurity program, with standards, policies, and procedures documented for OT trained cyber professionals

Engineering processes are cyber-informed and overall aligned with frameworks like ISA/IEC 62443, NIST CSF/800-82r3

Defined OT risk identification, tolerance & management strategy; including supply chain risks and compensatory controls

Extend segmentation between OT assets, including zone classification, network autonomy and wireless considerations

Apex predators

Ask Yourself:

1. Does my OT team have a voice and presence in InfoSec governance and risk management?
2. Does my OT environment have standards, policies and procedures bespoke to it's needs?
3. Are we relying on security-by-design concepts throughout OT lifecycle?

Help Yourself:

1. Implement security-by-design and cyber-informed engineering best practices
2. Create compensatory controls and lifecycle planning for legacy assets
3. Implement continuous risk management prioritizing safety in processes and procedures

In Conclusion

OT Maturity Assessment Themes:

1. Lack of CMDB / asset management roles and responsibilities
2. Unclear or overly permissive network boundaries and zones
3. Remote access falling outside of governance
4. Lack of basic monitoring and segmentation

Proposed Solutions

1. Strive for unified governance and risk management
2. Implement OT-specific visibility and response
3. Confirm documented network boundaries with penetration testing or purple team exercises
4. Empower cyber-informed engineering

Empowering Information Security professionals with the information they need to protect OT environments is a recipe for success

Questions?

Let’s connect & continue the conversation!

Linkedin.com/in/cyber-mandie-g